NotMarket
Yerel Güvenlik Testi Raporu

10 Ekim 2026 | Kaynak kod incelemesi ve izole ortam testleri

Kapsam ve sınırlar

Mevcut çalışma ağacı test edildi; kullanıcının mevcut değişiklikleri korunmuştur. Asıl API derlemesi başarılı: 0 hata, 0 uyarı. Docker/veritabanı/API çalışmadığından /tmp/notmarket-pentest altında izole API kopyası oluşturuldu. Orijinal Program.cs içindeki JWT, CORS, rate limiter, authorization ve controller kodları kullanıldı. Yalnızca başlangıç migration/seed/katalog işlemleri ve hosted background services kaldırıldı; UserSecretsId kaldırıldı ve yapay yerel yapılandırma kullanıldı. API Development ortamında 127.0.0.1:18766 üzerinde çalıştı ve test sonunda durduruldu. Test token'ları yalnızca bu kopyanın yapay anahtarıyla üretildi.

Gerçek veritabanı, kullanıcı hesapları, bulut servisleri, üretim HTTPS/proxy/WAF, bağımlılık güvenlik taraması ve uçtan uca IDOR/ödeme akışları test edilmedi. NuGet güvenlik verilerine ağ erişimi sağlanamadı. Bu rapor tam kapsamlı canlı sızma testi değildir.

Doğrulanan bulgular

F1 - Yerel belge servisinde dizin sınırı aşımı (orta, koşullu)

Kaynak: backend/NotMarket.Api/Services/LocalVerificationDocumentStorage.cs:53-61.
OpenReadAsync, normalize edilmiş yolu kök dizin metniyle StartsWith kullanarak karşılaştırıyor; sonuna dizin ayıracı eklemiyor. Testte App_Data/student-verifications-backup/canary.txt içine PENTEST_CANARY yazıldı. Servise ../student-verifications-backup/canary.txt verildiğinde içerik okundu. ../../outside.txt engellendi.

Bu, bileşen düzeyinde doğrulanmış bir sınır aşımıdır; herhangi bir dosyaya sınırsız erişim değildir. HTTP uçları belge yolunu veritabanından alıyor; dış kullanıcının bu yolu doğrudan kontrol edebildiği gösterilmedi. Servis Development ortamında kullanılıyor. Üretimde Supabase için aynı bulgu iddia edilmiyor.

Öneri: DeleteAsync içindeki rootWithSeparator yaklaşımını okuma işlemine de uygulamak; boş/kök/absolute yolları reddetmek ve gerekiyorsa sembolik bağlantı sınırlarını ayrıca ele almak.

F2 - Sahte PDF, başlık kontrolünden geçiyor (düşük/orta, koşullu)

Kaynak: Controllers/StudentVerificationController.cs:708 ve Controllers/StudentNoteSubmissionsController.cs:795.
Gerçek private IsPdfAsync metotları reflection ile çalıştırıldı. "%PDF-This is not a PDF" metni her iki kontrolde true; "plain text" false döndürdü. Kontroller dosyanın yalnızca ilk beş baytını doğruluyor.

Bu test tüm yükleme akışının başarıyla tamamlandığını, kötü amaçlı kod çalıştırıldığını veya antivirüs atlatıldığını göstermez. Geçersiz dosyalar sonraki inceleme/işleme adımlarını tüketebilir. Öğrenci kimliği belgesinin gerçekliğini PDF format doğrulaması tek başına kanıtlayamaz.

Öneri: Sınırlı kaynaklarla çalışan bir PDF parser ile yapısal doğrulama; gerekli tehdit modelinde zararlı içerik taraması; belge gerçekliği için bağımsız doğrulama.

F3 - Giriş uçlarında uygulama seviyesinde hız sınırı yok (orta)

Kaynak: Program.cs:400, Controllers/AuthController.cs:17 ve :66.
65 ardışık boş JSON admin giriş isteğinin tamamı 400 döndürdü; 429 alınmadı. Kaynak kodda tek rate limit politikası AnalyticsVisits ve yalnızca analitik uçta uygulanıyor. Global limiter veya auth endpoint limiter bulunmuyor.

Boş gövdeler model doğrulamada reddedildi; şifre doğrulama/gerçek kaba kuvvet saldırısı yapılmadı. Bulut/proxy tarafında dış koruma olup olmadığı bilinmiyor.

Öneri: Admin ve öğrenci girişlerine IP ve hesap bazlı hız sınırlaması, kontrollü geçici kilitleme ve deneme izleme.

Kaynak kod bulguları - dinamik olarak doğrulanmadı

- F4 (yüksek etki potansiyeli): AdminUsersController.UpdateStatus hesabı askıya alabiliyor fakat JWT doğrulama katmanında merkezi hesap durumu/revocation kontrolü yok. Admin API'leri AdminOnly rolüyle yetkileniyor; askıya alınan adminin mevcut token'ının süre sonuna kadar kabul edilmesi beklenir. Gerçek hesap/veritabanı ile doğrulanmadı. Bazı öğrenci işlemleri ayrıca hesap durumunu kontrol ediyor. Öneri: Merkezi aktif hesap/security stamp kontrolü ve kısa token ömrü/revocation mekanizması.
- F5 (ortama bağlı): docker-compose.yml, PostgreSQL portunu 5433:5432 ile tüm arayüzlere yayımlıyor. Docker kapalı olduğundan ağdan erişilebilirlik kanıtlanmadı. Öneri: geliştirmede 127.0.0.1:5433:5432; üretimde özel ağ.
- F6 (koşullu): Admin ve öğrenci token'ları localStorage içinde; XSS olursa okunabilir. XSS exploit bulunmadı veya çalıştırılmadı. CSP/oturum stratejisi ayrıca değerlendirilmeli.

Başarılı kontroller

78 HTTP isteği çalıştırıldı; ayrıntılar http-results.json içinde:

- Altı korunan endpoint anonim istekleri 401 ile reddetti.
- Student token ile admin erişimi ve Admin token ile student erişimi 403 döndürdü.
- Yanlış imzalı, süresi geçmiş ve alg=none JWT'ler 401 döndürdü.
- https://attacker.example Origin ile health yanıtında Access-Control-Allow-Origin yoktu; Development CORS bu origin'i yetkilendirmedi. Health'in 200 dönmesi CORS ihlali değildir.
- LaTeX validator: input, write18, csname, ^^ kodlama ve includegraphics örnekleri reddedildi; normal denklem kabul edildi. Bu, tüm TeX saldırılarına karşı kanıt değildir.

Kanıt ve yeniden üretim

http-results.json gerçek HTTP durumlarını içerir. http_probes.py yalnızca izole kopyanın localhost portuna ve yapay JWT anahtarına göre hazırlanmıştır; canlı ortama yönlendirilmemelidir. component-probes.cs gerçek servisleri/controller yardımcı metotlarını test eder; net10.0 console projesinde Microsoft.AspNetCore.App FrameworkReference ve NotMarket.Api ProjectReference ile çalıştırılabilir. Tüm dosya denemeleri /tmp/notmarket-pentest/storage içindeki yapay içerikle sınırlıdır. Test kopyası hâlen /tmp/notmarket-pentest altında; geçici klasör kalıcı teslim değildir.

Öncelik

Önce admin oturum iptali ve giriş korumaları; ardından dizin sınırı kontrolü ve PDF doğrulaması düzeltilmeli. Canlı güvenlik değerlendirmesini tamamlamak için izole PostgreSQL veritabanında iki öğrenci ve bir admin hesabıyla IDOR, askıya alınmış hesap, ödeme/indirme ve yükleme akışları test edilmeli; üretim WAF/firewall kuralları ayrıca incelenmeli.